

2026

Perform Threat Hunting Against 2 Machines

MOSSÉ CYBERSECURITY INSTITUTE

Student ID: 24niZSZPvqYEcB53AUYPe2z4w9X2

Table of Contents

Executive Summary..... 3

Investigation Approach..... 3

Compromised Machines..... 5

Indicators of Compromise (IOCs)..... 6

Recommendations..... 8

Limitations and Constraints..... 8

Assumptions..... 9

Executive Summary

During this threat-hunting investigation, forensic triage data collected from two Windows machines, hostnames 0000DQEE and 0001LXQEN, was analyzed to identify activity indicative of compromise. The datasets — covering domain users, logged-on users, user accounts, running processes, drivers, and persistence artifacts (registry, file, and service items) — were loaded into Pandas dataframes and reviewed for common indicators of compromise, including anomalous privileged-account activity, processes executing from non-standard, user-writable paths, and commands associated with privilege escalation or credential access.

The investigation found that host 0001LXQEN shows two independent, corroborating indicators of compromise: the domain administrator account (Administrator) was active on the machine alongside its assigned user, and a SYSTEM-privileged cmd.exe process was observed executing a non-standard script (run_pd.bat) from inside the user's own profile directory. No equivalent indicators were found on host 0000DQEE, although several secondary observations on that host (portable SSH tooling and a personal VPN client run under a service-style account) are flagged for the security team's awareness. Continued monitoring, credential rotation, and forensic follow-up on 0001LXQEN are recommended to fully contain and remediate the incident.

Investigation Approach

Forensic triage data for both machines was collected in a format consistent with FireEye Redline memory/endpoint analysis exports, covering Domain Users, Logged On Users, User Accounts, Windows Drivers, Windows Persistence File Items, Windows Persistence Registry Items, Windows Persistence Service Items, Windows Processes, Windows Processes Memory Sections, Windows Services, and Windows Tasks. Each category was exported as Parquet and loaded into Pandas dataframes inside a Jupyter Notebook for structured, repeatable analysis.

An investigation plan was used to make sure each dataset was checked systematically rather than at random. The plan takes the perspective of an attacker operating inside the environment: which accounts would they try to use, which processes would they run, and where would they try to hide persistence. Table 1 summarizes the categories of data reviewed and the common IOCs associated with each; Table 2 maps typical attacker techniques to the data categories and terms used to hunt for them.

Table 1: Categories of Data and Common Indicators of Compromise

Category	Common Indicators of Compromise (IOCs)
Domain Users	Unusual or unknown domain accounts Elevated privileges granted to an account (admin/system-level access) Accounts with weak or reused passwords
Logged On Users	Users logged in from multiple hosts (possible lateral movement) Accounts active at unusual times or in unexpected contexts A privileged account active on a standard workstation
User Accounts	Hidden or non-descriptive accounts (e.g. "svc_lw", "user123") Accounts that mimic legitimate service/process names Disabled accounts re-enabled without authorization

Windows Drivers	Unsigned or suspicious drivers Drivers loaded from non-standard paths Newly installed or unexpectedly modified drivers
Windows Persistence — File Items	Unusual files in persistence-related directories (System32, user profile, startup folders) Files with random or non-descriptive names
Windows Persistence — Registry Items	New/modified Run, RunOnce, or Services keys Registry entries pointing to non-legitimate executables
Windows Persistence — Service Items	New services with unusual names Services set to auto-start with unsigned executables
Windows Processes	Processes running from non-standard, user-writable paths (Temp, AppData, ProgramData) Administrative tools (cmd.exe, powershell.exe, reg.exe) invoked unexpectedly A process running with more privilege than expected for its context
Windows Processes — Memory Sections	Unusual DLLs/shellcode mapped into a process Signs of process injection
Windows Services	Services running from suspicious paths Services with unnecessary SYSTEM-level privileges
Windows Tasks	New or hidden scheduled tasks Tasks configured to run non-standard executables or commands

Table 2: Attack Types Mapped to Categories and IOC Terms

Attack Type	Category	Example IOC Terms
Malicious Windows commands	Windows Processes, Windows Services	cmd.exe, tasklist, ipconfig, systeminfo, net, query, wmic, sc, rundll32, powershell, mshta, netstat
Abusing accessibility features for persistence	Windows Services, Drivers, Persistence File Items	sethc.exe, utilman.exe, osk.exe, narrator.exe, magnify.exe
Modifying a Windows service	Windows Services, Persistence Registry Items	sc, binPath, ImagePath, HKLM, svchost.exe, winlogon.exe
Searching for credentials in the registry	Persistence Registry Items, User Accounts, Processes	reg.exe, reg query, HKCU, HKLM, lsass.exe, SAM, kerberos
Path interception	Persistence Registry Items, Windows Services	%SystemRoot%, unquoted service paths
Execution from a user-writable / masquerading path	Windows Processes, Persistence File Items	AppData, Temp, ProgramData, WindowsApps, non-standard .bat/.ps1 scripts

Compromised Machines

This section explains why host 0001LXQEN is assessed as compromised.

The Domain Users dataset identifies two domain accounts across the environment: timotlopez (member of the "seoul" group and "domain admins") and Administrator (member of "domain admins"). timotlopez is the assigned day-to-day user of both machines, so this baseline is used to spot activity that doesn't fit.

In [9]:

```
logged_users[logged_users.astype(str).apply(
    lambda row: row.str.contains('timotlopez|Administrator', case=False, na=False)
).any(axis=1)]
```

	domain-user	hostname	local-user	username
17	True	0000DQEE	False	timotlopez
47	True	0001LXQEN	False	timotlopez
55	True	0001LXQEN	False	Administrator

Figure 1: Account activity filtered for timotlopez and Administrator, across both hosts

The output shows that the Administrator domain-admin account is active only on 0001LXQEN — it does not appear on 0000DQEE at all. Only the assigned user (timotlopez) is present on 0000DQEE. A domain admin account showing activity on one specific end-user workstation, and not the other, is a strong indicator of credential compromise, privilege escalation, or lateral movement targeting that host.

The suspicious activity identified from the Windows Processes dataset for both machines is summarised in the table below.

Machine	Activity	Reason
0001LXQEN	cmd.exe (PID 5612) running as NT AUTHORITY\SYSTEM	SYSTEM-privileged shell invoking a script — high-confidence indicator of malicious execution
0001LXQEN	run_pd.bat, located in timotlopez's AppData\Local\Microsoft\WindowsApps	Non-standard script staged in a directory normally reserved for signed app-execution aliases — masquerading behaviour
0001LXQEN	KeePassXC.exe	Password-manager application — a potential credential-harvesting target if the host is already compromised
0001LXQEN / 0000DQEE	CyberGhost.Service.exe	Commercial VPN client present on both hosts — could mask outbound traffic if misused
0000DQEE	putty.exe and kitty-0.70.0.6.exe, run under the svc_lw account	Portable SSH/Telnet clients may indicate lateral-movement tooling or unauthorized remote access

In the User Accounts dataset, timotlopez holds both domain and local admin privileges on 0001LXQEN, which is consistent with the group membership already observed in the Domain Users dataset and is treated as this environment's baseline, not an IOC by itself. The Administrator account's presence on this host specifically, however, falls outside that baseline and is treated as the primary account-based indicator.

Indicators of Compromise (IOCs)

To hunt for processes launched from suspicious, user-writable locations, the Windows Processes dataframe for both hosts was filtered for references to Temp, AppData, or ProgramData — directories that legitimate system binaries do not normally execute from.

```
In [15]:
suspicious = processes[processes.astype(str).apply(
    lambda row: row.str.contains('Temp|AppData|ProgramData', case=False, na=False)
).any(axis=1)]
suspicious
```

	arguments	hostname
45	"C:\\Users\\timotlopez\\AppData\\Local\\Microsoft\\0...	0000DQEE
48	"C:\\Users\\timotlopez\\AppData\\Local\\Microsoft\\0...	0001LXQEN
79	C:\\Windows\\System32\\cmd.exe /C C:\\Users\\timotl...	0001LXQEN

	name	path	pid	username
45	OneDrive.exe	...AppData\\Local\\Microsoft\\OneDrive	3037	timotlopez
48	OneDrive.exe	...AppData\\Local\\Microsoft\\OneDrive	5043	timotlopez
79	cmd.exe	C:\\Windows\\System32\\cmd.exe	5612	NT AUTHORITY\\SYSTEM

Figure 2: Screenshot of filtered suspicious processes referencing Temp/AppData/ProgramData

Two OneDrive.exe entries are expected and benign — OneDrive legitimately runs from AppData\\Local\\Microsoft\\OneDrive. The third result is the key IOC: cmd.exe (PID 5612) on 0001LXQEN, running as NT AUTHORITY\\SYSTEM, with a command line pointing at a script inside timotlopez's profile.

Isolating this process id across the full process table confirms the full command line executed:

```
In [25]:
pd.set_option('display.max_colwidth', None)
processes[processes['pid'] == 5612]
```

```
arguments:  C:\\Windows\\System32\\cmd.exe /C
            C:\\Users\\timotlopez\\AppData\\Local\\Microsoft\\WindowsApps\\run_pd.bat
```

	hostname	name	path	pid	username
79	0001LXQEN	cmd.exe	C:\\Windows\\System32\\cmd.exe	5612	NT AUTHORITY\\SYSTEM

Figure 3: Full command line of PID 5612, confirming SYSTEM execution of run_pd.bat

This is a strong IOC for three reasons. First, cmd.exe is running as SYSTEM — the highest privilege level on Windows, normally reserved for the operating system itself, not for launching a user's personal script. Second, AppData\\Local\\Microsoft\\WindowsApps is a directory Windows normally uses only for small, signed "app execution alias" stub files, not custom .bat scripts, so a batch file placed there is consistent with an attacker disguising a payload inside a legitimate-looking path. Third, the file name run_pd.bat does not correspond to any known Windows or vendor utility, suggesting custom or attacker-supplied tooling. Combined with the Administrator account only being active on this same host, these two independent IOCs corroborate each other and point to 0001LXQEN as the compromised machine.

As a control check, the service-based persistence dataset was also reviewed for both hosts to see whether a malicious Windows service was responsible for triggering the script:

```
In [29]:
```

```

if 'hostname' in persistence_svc.columns and not persistence_svc.empty:
    print(persistence_svc[persistence_svc['hostname'] == '0001LXQEN'])
else:
    print("persistence_svc table is empty - no service-based persistence data available")

persistence_svc table is empty - no service-based persistence data available in this dataset.

```

Figure 4: No service-based persistence artifacts were collected for either host

No service-based persistence items were captured in this dataset for either machine, so this artifact category could not be used to confirm or rule out a malicious service as the trigger for run_pd.bat. A scheduled task remains the more likely trigger given the SYSTEM execution context, but this could not be conclusively pinned down within the scheduled-task data reviewed (see Limitations).

IOCs Explained in Plain Language

The technical evidence above can be summarised in everyday terms for readers who are not familiar with threat hunting or digital forensics:

A “master key” account showed up on a machine it doesn't belong to.

Administrator is like a master key that opens every door in the building, while timotlopez is a regular employee's own keycard that only opens their own office. Finding the master key being used at timotlopez's office — and nowhere else — is a red flag that someone either stole the master key or found another way to get master-key-level access to that one machine.

A system-level process ran a hidden, unofficial instruction sheet.

cmd.exe running as SYSTEM is like a security guard with full access to every room. Normally that guard only follows official, expected instructions. Here, the guard was seen opening a small, unofficial note (run_pd.bat) that had been left in an employee's personal desk drawer (their user profile folder) rather than the official supply closet (the standard system folders). A guard with full access following instructions left in someone's desk — instead of official orders — is exactly the kind of behaviour attackers rely on to get their own code running with maximum privilege.

A “lockbox” holding many passwords was present on the affected machine.

KeePassXC stores many passwords behind one master password, like a small lockbox that holds several house keys. If an attacker already has full access to this machine, that lockbox becomes an attractive target, since breaking into it could hand over many other passwords at once.

Remote-access and VPN tools were found on both machines.

Tools like PuTTY/KiTTY (remote login tools) and a personal VPN client can be used to connect to other machines or to disguise where a connection is really coming from. On their own they aren't proof of an attack — IT staff use these legitimately too — but combined with the findings above, they're worth double-checking with the machine's owner and against the company's approved software list.

Recommendations

A priority recommendation is to isolate the compromised machine, 0001LXQEN, by disconnecting it from the network to prevent further lateral movement or command-and-control activity. The SYSTEM-level cmd.exe process (PID 5612) and run_pd.bat should be preserved for forensic review, not simply killed, so the full payload and its trigger can be analyzed; a memory and disk image should be captured before any remediation begins.

Credentials for the Administrator (domain admin) and timotlopez accounts should be reset immediately, and any active sessions or Kerberos tickets tied to them invalidated. The KeePassXC vault present on 0001LXQEN should be treated as compromised — its master password should be changed and every credential stored inside it rotated.

Domain admin group membership and recent logon history should be audited fleet-wide to confirm the Administrator account was not used elsewhere. Interactive logons by domain admin accounts to standard workstations should be prohibited going forward, with a dedicated privileged access workstation or jump host used instead for legitimate admin tasks.

Application allow-listing (e.g., AppLocker or Windows Defender Application Control) should be deployed to block script execution from user-writable directories such as AppData, Temp, and WindowsApps — this would have prevented run_pd.bat from ever running. Detailed process and command-line logging (Windows Event ID 4688 with command-line auditing, or Sysmon) should be enabled and centrally collected so that future SYSTEM-level executions and their triggers are immediately visible, with timestamps.

Deploying a Security Information and Event Management (SIEM) platform to centralize logs, alongside an Endpoint Detection and Response (EDR) solution for real-time monitoring, would materially reduce the time to detect similar activity in the future. Finally, 0001LXQEN should be rebuilt from a known-good image rather than manually cleaned, given the SYSTEM-level nature of the compromise, and a fleet-wide hunt for the run_pd.bat filename and similar WindowsApps-staged scripts should be run to rule out further spread.

Limitations and Constraints

The datasets provided did not include reliable event timestamps, which prevented building a precise timeline of the compromise (initial access, escalation, and execution could not be sequenced with confidence).

The registry and file persistence tables contained roughly 12,000 rows combined, the large majority being standard Windows COM (CLSID) registrations rather than attacker-controlled entries. It was not practical to manually inspect every row, so it is possible a quieter persistence mechanism was missed within that volume.

No network telemetry (DNS, proxy, firewall, or netflow logs) was available, so command-and-control communication, tunnelling, or data exfiltration could not be confirmed or ruled out, including for the CyberGhost VPN client and PuTTY/KiTTY tooling observed.

As shown above, the service-based persistence dataset was empty for both hosts, which means this category could not be used as evidence either way.

The scheduled task dataset for 0001LXQEN was large and dominated by default Windows tasks (certificate enrollment, attestation, etc.); the specific task (if any) that triggered run_pd.bat could not be conclusively identified from the fields reviewed, which would require a full field-by-field review of every task's command/argument string.

Only two endpoints were provided for this investigation, with no Active Directory or domain-controller-level logon data available to confirm whether the Administrator account was used anywhere else in the environment.

Assumptions

It is assumed that the forensic artifacts (Parquet exports) accurately reflect the state of each host at the time of collection and were not altered between collection and analysis.

It is assumed that the Administrator account observed is the environment's built-in/domain administrator account, rather than an unrelated local account that happens to share the name.

Because timotlopez's domain and local admin privileges are consistent across the Domain Users and User Accounts datasets, this is assumed to be the pre-existing, legitimate baseline for that account rather than an IOC in itself — only the appearance of the separate Administrator account specifically on 0001LXQEN is treated as anomalous.

Software such as PuTTY, KiTTY, CyberGhost VPN, and KeePassXC was not confirmed against an official approved-software inventory; these are assumed not to be pre-approved corporate standard tools unless the organization confirms otherwise, and are flagged for review rather than treated as definitive malicious tooling.

The investigation assumes the collected artifacts represent a single point-in-time snapshot; no assumption is made about whether the compromise was ongoing, contained, or fully remediated at the time of collection.